

# Adaptive Web Vulnerability Scan Report

Target: http://127.0.0.1:3000/

Scan ID: fb30af7e-baaa-45ae-a97e-c0d7d727f79b

Pages  
25

Forms  
17

Endpoints  
110

Findings  
19

API endpoints  
174

GraphQL endpoints  
2

Average anomaly  
0

Passive score  
64

High-risk endpoints  
14

Schema fuzz probes  
0

Open ports  
1

Authenticated context  
No

## Scan Profile

Profile  
Bounty Standard

Detectors  
sqli, xss, csrf,  
auth\_bypass

API fuzzing  
Enabled

GraphQL checks  
Enabled

Rate limit / sec  
3.0

Severity split: High 2, Medium 17, Low 0

## Recon Intelligence

WAF  
Not detected

TLS  
Target is not HTTPS.

Screenshot  
failed

Missing headers  
3

Technologies: none

Open ports: 8000 dev-http

## Endpoint Risk Ranking

| Risk | Method | Source            | URL                                                      | Reasons                                                |
|------|--------|-------------------|----------------------------------------------------------|--------------------------------------------------------|
| 70   | GET    | directory-fuzzing | http://127.0.0.1:3000/openapi.json                       | openapi keyword, api keyword, directory-fuzzing source |
| 65   | get    | script-analysis   | http://127.0.0.1:3000/rest/user/authentication-details/  | auth keyword, rest keyword, user keyword               |
| 65   | get    | script-analysis   | http://127.0.0.1:3000/rest/user/login                    | login keyword, rest keyword, user keyword              |
| 60   | get    | script-analysis   | http://127.0.0.1:3000/rest/admin                         | admin keyword, rest keyword                            |
| 60   | get    | script-hidden-api | http://127.0.0.1:3000/Backup has been restored from      | backup keyword, rest keyword                           |
| 60   | post   | common-probe      | http://127.0.0.1:3000/api/graphql                        | graphql keyword, api keyword                           |
| 55   | get    | script-analysis   | http://127.0.0.1:3000/rest/user/change-password?current= | rest keyword, user keyword, parameterized              |
| 55   | get    | script-analysis   | http://127.0.0.1:3000/rest/user/security-question?email= | rest keyword, user keyword, parameterized              |

| Risk | Method | Source            | URL                                                | Reasons                                     |
|------|--------|-------------------|----------------------------------------------------|---------------------------------------------|
| 55   | get    | common-probe      | http://127.0.0.1:3000/rest/products/search?q=apple | rest keyword, search keyword, parameterized |
| 55   | GET    | directory-fuzzing | http://127.0.0.1:3000/admin                        | admin keyword, directory-fuzzing source     |
| 55   | GET    | directory-fuzzing | http://127.0.0.1:3000/debug                        | debug keyword, directory-fuzzing source     |
| 55   | GET    | directory-fuzzing | http://127.0.0.1:3000/swagger                      | swagger keyword, directory-fuzzing source   |
| 55   | GET    | directory-fuzzing | http://127.0.0.1:3000/swagger.json                 | swagger keyword, directory-fuzzing source   |
| 50   | get    | script-analysis   | http://127.0.0.1:3000/rest/saveLoginIp             | login keyword, rest keyword                 |
| 45   | post   | common-probe      | http://127.0.0.1:3000/graphql                      | graphql keyword                             |
| 45   | GET    | directory-fuzzing | http://127.0.0.1:3000/upload                       | upload keyword, directory-fuzzing source    |
| 40   | get    | script-analysis   | http://127.0.0.1:3000/api/Users                    | api keyword, user keyword                   |
| 40   | get    | script-analysis   | http://127.0.0.1:3000/rest/order-history           | rest keyword, order keyword                 |
| 40   | get    | script-analysis   | http://127.0.0.1:3000/rest/track-order             | rest keyword, order keyword                 |
| 40   | get    | script-analysis   | http://127.0.0.1:3000/rest/user                    | rest keyword, user keyword                  |
| 40   | get    | script-analysis   | http://127.0.0.1:3000/rest/user/reset-password     | rest keyword, user keyword                  |
| 40   | get    | script-analysis   | http://127.0.0.1:3000/rest/user/whoami             | rest keyword, user keyword                  |
| 35   | get    | script-analysis   | http://127.0.0.1:3000/accounting                   | account keyword                             |
| 35   | get    | script-analysis   | http://127.0.0.1:3000/file-upload                  | upload keyword                              |
| 35   | get    | script-analysis   | http://127.0.0.1:3000/login                        | login keyword                               |

### Scan Timeline

| Progress | Phase      | Message                                                               | Timestamp                        |
|----------|------------|-----------------------------------------------------------------------|----------------------------------|
| 5%       | startup    | Target reachable and scan initialized                                 | 2026-05-14T07:09:14.879486+00:00 |
| 30%      | crawl      | Mapped 25 pages, 17 forms, and 110 endpoints                          | 2026-05-14T07:09:38.854985+00:00 |
| 88%      | validation | Validated 19 candidate findings                                       | 2026-05-14T07:16:05.727235+00:00 |
| 92%      | recon      | Passive recon, endpoint risk, TLS, and low-impact discovery completed | 2026-05-14T07:16:10.686443+00:00 |

### Detector Registry

**sqli  
injection**

query / form / api

Tests query parameters, forms, and API-like inputs for error-based, boolean-based, and time-delay SQL injection signals.

**xss  
client-side**

query / form / api / dom

Checks reflected, DOM-rendered, and persistence-oriented XSS indicators across common input surfaces.

**csrf  
workflow**

form

Flags state-changing forms and endpoints that appear to lack anti-CSRF protections.

**auth\_bypass  
authorization**

page / api

Looks for privileged or admin-style resources that are reachable without expected access controls.

## API Surface

API endpoints  
174

GraphQL endpoints  
2

Parameterized endpoints  
3

Methods  
GET, POST

**Discovery sources:** bundle-candidate, common-probe, crawler, hidden-api, id-enumeration, script-analysis, script-hidden-api

## Schema-Aware Fuzzing

| Method                               | URL | Fields | Status | Reflected Fields |
|--------------------------------------|-----|--------|--------|------------------|
| No REST schema fuzz probes recorded. |     |        |        |                  |

| GraphQL URL                        | Fields | Status | Data Keys | Errors |
|------------------------------------|--------|--------|-----------|--------|
| No GraphQL schema probes recorded. |        |        |           |        |

## Detector Timings

| Detector    | Elapsed (ms) | Findings |
|-------------|--------------|----------|
| sqli        | 324696.65    | 2        |
| xss         | 58779.72     | 0        |
| csrf        | 0.12         | 17       |
| auth_bypass | 3394.26      | 0        |

## Findings

### SQLI | HIGH | CVSS 7.8

POST form field status produced an anomalous response under SQLi probing.

- **URL:** http://127.0.0.1:3000/api/Feedbacks
- **Method:** post
- **Parameter:** status
- **Confidence:** low (0.42)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** error-signature
- **Reason:** Database error signature matched the SQLi payload response.
- **OWASP Category:** A03:2021-Injection
- **Request PoC:** POST http://127.0.0.1:3000/api/Feedbacks with parameter status using payload ' OR '1'='1
- **Payload:** ' OR '1'='1
- **Request snapshot:** POST http://127.0.0.1:3000/api/Feedbacks body[status]=' OR '1'='1
- **Response snapshot:** <html> <head> <meta charset='utf-8'> <title>Error: WHERE parameter &quot;captchaId&quot; has invalid &quot;undefined&quot; value</title> <style>\* { margin: 0; padding: 0; outline: 0; } body { padd...
- **Response evidence:** status 500 -> 500, length 2310 -> 2310
- **Remediation:** Sanitize server-side form inputs and use bound query parameters.
- **Code Snippet:**

```
cursor.execute('SELECT * FROM users WHERE username = %s', (username,))
```

### SQLI | HIGH | CVSS 7.8

POST form field data produced an anomalous response under SQLi probing.

- **URL:** http://127.0.0.1:3000/api/Feedbacks
- **Method:** post
- **Parameter:** data
- **Confidence:** low (0.42)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** error-signature
- **Reason:** Database error signature matched the SQLi payload response.
- **OWASP Category:** A03:2021-Injection
- **Request PoC:** POST http://127.0.0.1:3000/api/Feedbacks with parameter data using payload ' OR '1'='1
- **Payload:** ' OR '1'='1
- **Request snapshot:** POST http://127.0.0.1:3000/api/Feedbacks body[data]=' OR '1'='1
- **Response snapshot:** <html> <head> <meta charset='utf-8'> <title>Error: WHERE parameter &quot;captchaId&quot; has invalid &quot;undefined&quot; value</title> <style>\* { margin: 0; padding: 0; outline: 0; } body { padd...
- **Response evidence:** status 500 -> 500, length 2310 -> 2310
- **Remediation:** Sanitize server-side form inputs and use bound query parameters.
- **Code Snippet:**

```
cursor.execute('SELECT * FROM users WHERE username = %s', (username,))
```

## CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/rest/user/login
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/rest/user/login with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status - -> -, length - -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

## CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/graphql
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/graphql with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status - -> -, length - -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

## CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/api/graphql
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -

- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/api/graphql with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

## CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/api/Addresss
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/api/Addresss with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

## CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/api/Cards
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/api/Cards with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

## CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/api/Challenges
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/api/Challenges with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

## CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/api/Deliverys
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/api/Deliverys with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

## CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/api/Feedbacks
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/api/Feedbacks with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

## CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/api/Hints
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/api/Hints with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

## CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/api/Products
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/api/Products with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -

- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

### CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/api/Quantity
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/api/Quantity with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

### CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/api/Recycles
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/api/Recycles with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

### CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/api/SecurityQuestions
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/api/SecurityQuestions with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

### CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/rest/captcha
- **Method:** post

- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/rest/captcha with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

## CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/rest/continue-code
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/rest/continue-code with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

## CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/rest/deluxe-membership
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/rest/deluxe-membership with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -
- **Remediation:** Add per-request CSRF tokens and validate them server-side.

## CSRF | MEDIUM | CVSS 6.1

POST form does not expose an obvious CSRF token field

- **URL:** http://127.0.0.1:3000/rest/memories
- **Method:** post
- **Parameter:** -
- **Confidence:** medium (-)
- **Priority:** P2
- **Validation state:** requires-review
- **Validation signals:** -
- **Reason:** -
- **OWASP Category:** Unknown
- **Request PoC:** POST http://127.0.0.1:3000/rest/memories with parameter - using payload -
- **Payload:** -
- **Request snapshot:** -
- **Response snapshot:** -
- **Response evidence:** status -> -, length -> -



- **Remediation:** Add per-request CSRF tokens and validate them server-side.

## Raw Findings Table

| Detector | Severity | CVSS | Priority | Confidence | Signals         | Method | Parameter | URL                                   | Evi                                                             |
|----------|----------|------|----------|------------|-----------------|--------|-----------|---------------------------------------|-----------------------------------------------------------------|
| sqli     | high     | 7.8  | P2       | low (0.42) | error-signature | post   | status    | http://127.0.0.1:3000/api/Feedbacks   | PO<br>for<br>sta<br>pro<br>an<br>anc<br>res<br>unc<br>SQ<br>pro |
| sqli     | high     | 7.8  | P2       | low (0.42) | error-signature | post   | data      | http://127.0.0.1:3000/api/Feedbacks   | PO<br>for<br>dat<br>pro<br>an<br>anc<br>res<br>unc<br>SQ<br>pro |
| csrf     | medium   | 6.1  | P2       | medium (-) | -               | post   | -         | http://127.0.0.1:3000/rest/user/login | PO<br>for<br>not<br>an<br>CS<br>tok                             |
| csrf     | medium   | 6.1  | P2       | medium (-) | -               | post   | -         | http://127.0.0.1:3000/graphql         | PO<br>for<br>not<br>an<br>CS<br>tok                             |
| csrf     | medium   | 6.1  | P2       | medium (-) | -               | post   | -         | http://127.0.0.1:3000/api/graphql     | PO<br>for<br>not<br>an<br>CS<br>tok                             |
| csrf     | medium   | 6.1  | P2       | medium (-) | -               | post   | -         | http://127.0.0.1:3000/api/Addresss    | PO<br>for<br>not<br>an<br>CS<br>tok                             |
| csrf     | medium   | 6.1  | P2       | medium (-) | -               | post   | -         | http://127.0.0.1:3000/api/Cards       | PO<br>for<br>not<br>an<br>CS<br>tok                             |
| csrf     | medium   | 6.1  | P2       | medium (-) | -               | post   | -         | http://127.0.0.1:3000/api/Challenges  | PO<br>for<br>not<br>an<br>CS<br>tok                             |
| csrf     | medium   | 6.1  | P2       | medium (-) | -               | post   | -         | http://127.0.0.1:3000/api/Deliverys   | PO<br>for<br>not<br>an                                          |

| Detector | Severity | CVSS | Priority | Confidence | Signals | Method | Parameter | URL                                          | Evi                  |
|----------|----------|------|----------|------------|---------|--------|-----------|----------------------------------------------|----------------------|
|          |          |      |          |            |         |        |           |                                              | CS tok               |
| csrf     | medium   | 6.1  | P2       | medium (-) | -       | post   | -         | http://127.0.0.1:3000/api/Feedbacks          | PO for not an CS tok |
| csrf     | medium   | 6.1  | P2       | medium (-) | -       | post   | -         | http://127.0.0.1:3000/api/Hints              | PO for not an CS tok |
| csrf     | medium   | 6.1  | P2       | medium (-) | -       | post   | -         | http://127.0.0.1:3000/api/Products           | PO for not an CS tok |
| csrf     | medium   | 6.1  | P2       | medium (-) | -       | post   | -         | http://127.0.0.1:3000/api/Quantitys          | PO for not an CS tok |
| csrf     | medium   | 6.1  | P2       | medium (-) | -       | post   | -         | http://127.0.0.1:3000/api/Recycles           | PO for not an CS tok |
| csrf     | medium   | 6.1  | P2       | medium (-) | -       | post   | -         | http://127.0.0.1:3000/api/SecurityQuestions  | PO for not an CS tok |
| csrf     | medium   | 6.1  | P2       | medium (-) | -       | post   | -         | http://127.0.0.1:3000/rest/captcha           | PO for not an CS tok |
| csrf     | medium   | 6.1  | P2       | medium (-) | -       | post   | -         | http://127.0.0.1:3000/rest/continue-code     | PO for not an CS tok |
| csrf     | medium   | 6.1  | P2       | medium (-) | -       | post   | -         | http://127.0.0.1:3000/rest/deluxe-membership | PO for not an CS tok |
| csrf     | medium   | 6.1  | P2       | medium (-) | -       | post   | -         | http://127.0.0.1:3000/rest/memories          | PO for not an CS tok |